

DEREXI UNDER ATTACK

A Fictional APT38 / BeagleBoyz Intrusion Scenario Mapped to MITRE ATT&CK;

SCENARIO STATUS FICTIONAL / EDUCATIONAL. DeRexi and the compromise described in this report are fictional. APT38's capabilities and ATT&CK; mappings are grounded in public CISA and MITRE reporting; the scenario applies those documented behaviors to a hypothetical banking-policy platform.

Organization: DeRexi: Policy Pilot - a policy-governance platform used by banks and financial institutions to store, retrieve and operationalize internal policies and procedures.

Threat actor: APT38 / BeagleBoyz, a North Korean state-sponsored cluster associated with financially motivated operations against banks, SWIFT endpoints and ATMs.

Incident premise: APT38 targets DeRexi as a strategic third-party access point. Rather than attacking one bank at a time, the actor attempts to compromise DeRexi's internal environment to learn how client institutions operate, obtain privileged access, and create opportunities for downstream financial fraud.

What happened to DeRexi?

In this fictional scenario, a DeRexi employee receives a convincing spearphishing email disguised as a banking-client policy review request. The attached document is malicious. When opened, it initiates attacker-controlled execution on the employee workstation. APT38 then uses built-in Windows tooling to execute commands, establishes persistence, attempts to obtain additional account access, and begins discovering DeRexi's files and internal network resources.

The attackers' objective is not simply to steal DeRexi documents. Because DeRexi services financial institutions, its environment contains valuable operational context: policy-owner directories, escalation procedures, authentication workflows, incident-response guidance, and potentially client-specific policy repositories. That knowledge could help an adversary understand where financial controls exist and how employees are instructed to respond to suspicious activity.

As the intrusion progresses, the actor collects useful local data and attempts to reduce forensic evidence by deleting artifacts and modifying timestamps. The security team detects unusual PowerShell activity, abnormal file/share enumeration and suspicious service creation. DeRexi isolates the affected systems before evidence confirms any successful compromise of a client bank.

INCIDENT SEVERITY HIGH. The hypothetical incident creates both direct risk to DeRexi and supply-chain risk to banking clients. No client compromise is assumed in this report; the scenario stops at a confirmed DeRexi intrusion with potential downstream exposure.

The banking connection

MITRE describes APT38 as a North Korean state-sponsored group specializing in financial cyber operations and documents targeting of banks, financial institutions, SWIFT endpoints and ATMs. CISA's FASTCash 2.0 advisory describes BeagleBoyz activity against financial institutions and warns of operational risk beyond direct theft.

A policy-governance vendor serving banks could be attractive because policy information reveals how organizations are expected to operate. Even when policy documents do not contain passwords, they can expose security processes, approval chains, privileged roles, incident escalation paths, payment controls and terminology used inside client organizations.

THREAT MODEL The fictional motive is strategic access and intelligence: compromise the platform provider, understand client procedures, seek credentials or privileged pathways, and use that knowledge to support later financial operations. This is an analytical scenario - not a claim that APT38 has targeted DeRexi or an equivalent real product.

Potentially exposed DeRexi assets

Asset	Why an attacker may value it
Policy repository	Reveals security, payment, access-control and incident procedures.
Employee / policy-owner directory	Identifies roles, approvers, administrators and escalation contacts.
Authentication environment	May provide a path toward privileged DeRexi accounts if compromised.
Audit / usage data	Shows which policies, systems or procedures are important to client operations.
Client configuration metadata	Could help an attacker distinguish customers and understand platform relationships.

Mapping the fictional DeRexi intrusion

The procedure column below is fictional; the ATT&CK; technique selection is based on behaviors MITRE attributes to APT38. This lets the scenario remain realistic without presenting invented events as historical facts.

Tactic	ID	Technique	DeRexi scenario procedure
Initial Access	T1566.001	Spearphishing Attachment	A DeRexi analyst receives a malicious attachment disguised as a client policy-review document.
Execution	T1059.001	PowerShell	After user execution, the actor abuses PowerShell for commands and operational tasks on the workstation.
Persistence	T1543.003	Windows Service	A malicious service is created so attacker access can persist after reboot.
Credential Access	T1110	Brute Force	The actor attempts access to additional DeRexi accounts where credentials are not already known.
Discovery	T1083	File and Directory Discovery	The actor searches policy repositories and local directories to identify useful data.
Discovery	T1135	Network Share Discovery	Internal shares are enumerated to locate repositories and administrative resources.
Collection	T1005	Data from Local System	Selected local data is staged for attacker use.
Defense Evasion	T1070.004	File Deletion	Malware/tools and temporary artifacts are deleted to reduce evidence.
Defense Evasion	T1070.006	Timestomp	File timestamps are altered to make suspicious artifacts blend with surrounding files.

HOW TO READ THIS Example: APT38's documented use of spearphishing attachments maps to Initial Access / T1566.001. In the fictional incident, that same known behavior is applied to a DeRexi employee receiving a malicious client-themed document.

From phishing email to containment

08:42 - Initial Access

A DeRexi employee receives a client-themed email containing a malicious policy-review attachment.

08:47 - Execution

The attachment is opened. Endpoint telemetry records unusual PowerShell execution.

09:03 - Persistence

A previously unseen Windows service appears on the endpoint.

09:18 - Credential Activity

Authentication monitoring identifies repeated access attempts against additional internal accounts.

09:31 - Discovery

The compromised endpoint begins enumerating directories and network shares associated with internal policy resources.

09:46 - Collection

Security telemetry indicates selected local information is being accessed and staged.

10:02 - Defense Evasion

Temporary artifacts disappear and timestamp anomalies are detected.

10:09 - Detection

The SOC correlates PowerShell, service-creation and discovery alerts and declares a suspected compromise.

10:16 - Containment

The endpoint is isolated, affected credentials are disabled, active sessions are revoked and client-facing access paths are restricted.

10:35 - Escalation

Incident response, leadership, legal/compliance and banking-client communication procedures are activated.

OUTCOME For the purposes of this case study, DeRexi contains the intrusion before investigators find evidence of a successful compromise of a client banking environment. The incident is nevertheless treated as a potential supply-chain event until forensic review is complete.

What the compromise could mean

Risk area	Potential consequence
Confidentiality	Unauthorized access to internal or client policy information, directories and operational metadata.
Integrity	Attackers could attempt to alter policy content, guidance or configuration, creating dangerous misinformation for users.
Availability	Containment may require taking portions of DeRexi offline, interrupting client access to policy guidance.
Credential / identity risk	Compromised accounts could allow the actor to impersonate employees or administrators.
Banking client risk	Knowledge of client controls and procedures could support downstream social engineering or intrusion attempts.
Regulatory / reputational risk	A compromise of a policy platform used by regulated financial institutions could trigger notification, audit and trust concerns.

Why integrity is especially important for DeRexi

DeRexi exists to help employees obtain trustworthy policy guidance. That makes content integrity a security requirement, not merely a documentation concern. If an attacker altered an incident-response instruction, approval threshold, payment procedure or escalation contact, a user could confidently follow information that is technically available but no longer trustworthy.

How DeRexi responds

Contain. Isolate affected endpoints, revoke sessions, disable suspected accounts and restrict administrative access.

Preserve evidence. Centralize endpoint, identity, application and cloud logs so attacker deletion on one host does not erase the investigation trail.

Validate policy integrity. Compare policy documents and versions against trusted hashes/version history and identify unauthorized changes.

Protect privileged access. Require phishing-resistant MFA and separate administrative identities from normal user accounts.

Detect APT38-style behaviors. Alert on suspicious PowerShell, new services, repeated authentication attempts, unusual share enumeration, file deletion and timestamp anomalies.

Segment clients. Architect tenant and administrative boundaries so compromise of one employee or component cannot become unrestricted access to every banking customer.

Coordinate banking notifications. Use predefined incident escalation and client communication procedures when a compromise could affect regulated financial institutions.

POLICY PILOT CONNECTION This fictional incident reinforces DeRexi's own product purpose: during a high-pressure security event, employees need fast, current and trustworthy procedures. The platform must therefore protect not only access to policies, but the integrity, version history and ownership of the guidance itself.

Incident conclusion

This fictional case study places a real financial-sector threat actor into the environment DeRexi is designed to serve. APT38 / BeagleBoyz is a credible adversary model because public reporting documents its focus on financial institutions and its use of techniques spanning phishing, command execution, persistence, credential attacks, discovery, collection and defense evasion.

The scenario demonstrates how MITRE ATT&CK; can turn a fictional incident into a structured, defensible analysis. Instead of saying only that 'DeRexi was hacked,' the report identifies the attacker's objective at each stage, the technique used to achieve it, the evidence defenders would expect to observe and the controls that could interrupt the attack.

Most importantly, the scenario shows why a policy-governance provider serving banks must be treated as part of the financial-sector security ecosystem. Protecting policy data, privileged access, audit trails and client separation is essential because compromise of a trusted platform can create risk beyond the vendor itself.

EVIDENCE BASIS

CISA AA20-239A - FASTCash 2.0: North Korea's BeagleBoyz Robbing Banks. CISA, Treasury, FBI and USCYBERCOM describe North Korean bank-targeting activity, FASTCash ATM cash-outs, SWIFT abuse, malware/IOCs and risks to the Financial Services sector.

MITRE ATT&CK; - APT38 (G0082). MITRE identifies APT38 as a North Korean state-sponsored group specializing in financial cyber operations, lists BeagleBoyz as an associated group, and documents the techniques used as the evidence basis for this fictional mapping.

ACADEMIC DISCLOSURE All events involving DeRexi in this report are fictional and were created solely for the assignment. Real-world claims about APT38 are separated from scenario-specific assumptions so that the report does not misrepresent fictional activity as a historical incident.